

Bölüm 5 & Bölüm 6

Siber Güvenlik Boyutu, Geliştirme/Savunma Teknikleri ve Modern Altyapılarda MTU Dinamikleri

TÜRKÇE DOKÜMANTASYON

Bölüm 5: Siber Güvenlik Boyutu ve Geliştirme/Savunma Teknikleri

Katman 1 ve Katman 2 seviyesindeki açıklar yazılımsal güvenlik duvarları (WAF'lar, kurumsal firewall'lar) tarafından **görülemez**. Çünkü o cihazlar Katman 3 ve yukarısını inceler. Bu yüzden buradaki saldırılar çok ölümcüldür.

1. MAC Flooding (Switch Felç Etme) Saldırısı

Kurumsal bir switch, hangi portuna hangi MAC adresli cihazın bağlı olduğunu hafızasındaki **CAM (Content Addressable Memory) Tablosunda** tutar. Bir paket geldiğinde bu tabloya bakar ve paketi sadece ilgili porta gönderir.

Saldırgan, switch'e bağlı bir porttan saniyeler içinde binlerce sahte kaynak MAC adresine sahip paket fırlatır (MAC Flooding). Switch'in CAM tablosunun hafıza kapasitesi sınırlıdır. Tablo sahte kayıtlarla tamamen dolduğunda switch akıl tutulması yaşar ve koruma moduna geçer.

Saldırı Sonucu: Switch, bir "Hub" gibi davranmaya başlar. Yani gelen her paketi, hedefi neresi olursa olsun tüm portlara broadcast olarak fırlatır. Saldırgan artık ağdaki diğer tüm şirket çalışanlarının trafiğini hiçbir ek çaba sarf etmeden dinleyebilir (Sniffing).

Savunma / Hardening Teknikleri (Port Security)

Kurumsal switch'lerde port seviyesinde sıkılaştırma yapılır. Port başına öğrenilebilecek maksimum MAC adresi sayısı sınırlandırılır.

```
switchport port-security maximum 1
switchport port-security violation shutdown
```

Eğer o porttan birden fazla farklı MAC adresi görülürse switch portu otomatik olarak kapatır (shutdown) veya saldırıncının paketlerini drop eder.

2. MAC Spoofing (Kimlik Hırsızlığı)

Şirket ağlarında genellikle "MAC tabanlı kimlik doğrulama" (MAB) veya statik IP atamaları kullanılır. Saldırgan, hedef aldığı bir yöneticinin bilgisayarının MAC adresini kendi ağ kartına kopyalar:

```
ip link set dev eth0 down
ip link set dev eth0 address AA:BB:CC:DD:EE:FF
ip link set dev eth0 up
```

Saldırı Sonucu: Switch ve DHCP sunucusu, saldırıncı o şirketin yetkili yöneticisi sanarak ağa dahil eder ve tüm yetkileri verir.

Savunma / Geliştirme Teknikleri (802.1X Kimlik Doğrulama)

Ağa bağlanırken sadece MAC adresine güvenilmemelidir. **802.1X (RADIUS/TACACS+)** protokolü altyapıya entegre edilerek, cihaz kabloyu taktığı an kullanıcı adı/şifre veya dijital sertifika ile kimlik doğrulaması yapmaya zorlanmalıdır. Kimlik doğrulamadan geçemeyen cihazın portuna switch elektrik vermez.

Bölüm 6: Modern Sistem Mimarisinde MTU ve "Karanlık" Ağ Sorunları

Bir DevOps veya Platform Mühendisi olarak en çok karşılaşılabilecek sorunlardan biri, tünelleme (encapsulation) teknolojileridir. VXLAN, IPsec VPN veya GRE Tunnel gibi teknolojiler, mevcut paketin üzerine ekstra kendi başlıklarını (Header) eklerler. Örneğin standart bir paket 1500 byte ise, üzerine VXLAN başlığı bindiğinde paket 1550 Byte olur.

Eğer senin fiziksel ağındaki (Underlay) switch'lerin MTU sınırı hala 1500 byte ise, bu tünel paketleri kapılardan geçemez. Router'lar paketleri parçalamaya çalışır, parçalanamayan paketler ise doğrudan drop edilir. Kullanıcı sistemi açtığında web sitesinin yarısının yüklendiğini, büyük dosyaların (Örn: Docker imajları push edilirken) yarıda kilitlendiğini görür ama küçük paketler (Ping gibi) sorunsuz çalışır. Buna ağ dünyasında **MTU Black Hole (Kara Delik)** denir.

Mimari Çözüm: Jumbo Frames

Modern veri merkezlerinde ve bulut altyapılarında bu sorunun önüne geçmek için fiziksel switch ve sunucuların MTU değeri varsayılan 1500'den 9000 Byte (Jumbo Frames) seviyesine yükseltilir. Böylece araya tünel başlıkları girse bile paketler asla parçalanmadan, tek parça halinde ve ışık hızında iletilir.



Section 5 & Section 6

Cybersecurity Perspective, Defense Techniques, and MTU Dynamics in Modern Architectures

ENGLISH DOCUMENTATION



Section 5: Cybersecurity Perspective & Defense/Hardening Techniques

Vulnerabilities at Layer 1 and Layer 2 **cannot be seen** by software-defined security solutions (WAFs, enterprise firewalls). This is because those devices inspect Layer 3 and above. Consequently, attacks at these lower layers are highly destructive.

1. MAC Flooding (Paralyzing the Switch)

An enterprise switch keeps track of which device (MAC address) is connected to which physical port in its memory table, known as the **CAM (Content Addressable Memory) Table**. When a packet arrives, the switch checks this table and forwards the packet only to the destination port.

An attacker sends thousands of packets with fake source MAC addresses to a single switch port within seconds (MAC Flooding). Because the CAM table has limited memory, it quickly fills up with these fake entries, causing the switch to malfunction and enter a fail-safe mode.

The Attack Result: The switch begins acting like a "Hub". This means it broadcasts every incoming packet to all physical ports, regardless of the target. The attacker can now monitor (Sniff) the network traffic of all other corporate users without any extra effort.

Defense / Hardening Techniques (Port Security)

Enterprise switches must be hardened at the port level by limiting the maximum number of MAC addresses a port can learn:

```
switchport port-security maximum 1
switchport port-security violation shutdown
```

If more than the allowed number of MAC addresses is detected on that port, the switch automatically shuts down the port or drops the attacker's packets.

2. MAC Spoofing (Identity Theft)

Many corporate environments use "MAC-Based Authentication" (MAB) or static IP assignments. An attacker copies the MAC address of an authorized target device (like an administrator's laptop) onto their own network card:

```
ip link set dev eth0 down
ip link set dev eth0 address AA:BB:CC:DD:EE:FF
ip link set dev eth0 up
```

The Attack Result: The switch and DHCP server mistake the attacker for the authorized corporate user and grant them full network access and privileges.

Defense / Hardening Techniques (802.1X Authentication)

You should never trust MAC addresses alone, as they are very easy to spoof. Instead, integrate **802.1X (RADIUS/TACACS+)** authentication. When a device plugs in a cable, it must authenticate using a username/password or a digital certificate. The switch will not allow data traffic on the port until authentication succeeds.



Section 6: MTU and "Dark" Network Issues in Modern System Architecture

As a DevOps or Platform Engineer, encapsulation (tunneling) technologies like VXLAN, IPsec VPN, or GRE Tunnel will be one of the most challenging areas you troubleshoot. These technologies add their own wrapping headers on top of existing data packets. For example, a standard IP packet is up to 1500 bytes (MTU). When you add a VXLAN header, the packet size grows to 1550 Bytes.

If the physical switches in your underlay network are still configured with the default 1500-byte MTU, these large encapsulated packets cannot pass. Routers will try to fragment them, and if they cannot, the packets are dropped. Users will complain that websites load only halfway, or large files (like pushing Docker images) freeze mid-way, while small packets (like Ping) work perfectly. In networking, this is called an **MTU Black Hole**.

Architectural Solution: Jumbo Frames

To prevent this issue in modern data centers, Kubernetes environments, and cloud infrastructures, the MTU of physical switches and servers is increased from the default 1500 to 9000 Bytes (Jumbo Frames). This ensures that even with additional tunneling headers, packets are never fragmented, allowing them to travel in one piece with maximum performance.